CASE STUDY

The Citrix NetScaler SAML IdP Memory Overread (CVE-2026-3055): A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people who carried this one were the administrators who run NetScaler ADC and NetScaler Gateway as a SAML identity provider, the single sign-on front door their users log in through. On 23 March 2026 Citrix published bulletin CTX696300 for CVE-2026-3055, an input-validation flaw that lets an unauthenticated request read memory it should not, which it said it found internally [1] (**Confirmed**). Four days later a research team's honeypots saw exploitation [11] (**Reported**), and on 30 March CISA added the flaw to its Known Exploited Vulnerabilities (KEV) catalog with a three-day deadline [4] [6] (**Confirmed**).

What leaks can outlive a patch: in watchTowr's testing the overread returned an authenticated administrative session ID [11] (**Demonstrated**), the session-theft pattern that made CitrixBleed (CVE-2023-4966) a ransomware entry point in 2023 [17] (**Confirmed**).

Key facts at a glance

Field	Value
Product	Customer-managed NetScaler ADC and Gateway 14.1 and 13.1, with 13.1 FIPS and NDcPP; the vendor updated its managed cloud services and Adaptive Authentication [1] (**Confirmed**)
Flaw	Insufficient input validation leading to memory overread; CWE-125 Out-of-bounds Read [1] [3] (**Confirmed**)
Score	CVSS v4.0 9.3 Critical, AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:L/SI:L/SA:L [1] (**Confirmed**)
Precondition	Configured as a SAML IdP (a SAML IdP profile in the running configuration) [1] (**Confirmed**)
Fixed builds	14.1-60.58; 14.1-66.59 and later; 13.1-62.23 and later; 13.1-FIPS and 13.1-NDcPP 13.1-37.262 and later [1] (**Confirmed**)
Discovery	"Identified internally" per the vendor [1] (**Confirmed** as the vendor's statement)
KEV	Added 30 Mar 2026, due 2 Apr 2026 (three days), ransomware use Unknown [4] [5] (**Confirmed**)
First reported exploitation	27 Mar 2026, honeypots, known threat-actor addresses [11] (**Reported**)
Actor and victims	None named, nor any sector or exposure count, in the vendor, CVE, NVD, KEV, CISA, CERT-EU, watchTowr or Rapid7 records [1] to [15] (**Inferred** from the absence)

Key findings

- One CVE, at least two leaks. watchTowr found overreads on two separate SAML and WS-Federation login endpoints under the single CVE, and reported a further one that became CVE-2026-8451 three months later [11] [12] [13] (**Demonstrated** for the two; that the further report became CVE-2026-8451 **Reported**; the fix **Confirmed**).
- The window from bulletin to KEV was seven days, and from first reported exploitation to the federal deadline six [1] [4] [11] (**Confirmed** dates; the exploitation date **Reported**).
- The 14.1 affected range is easy to misread; 14.1-66.x builds before 66.59 also need the fix [1] [3] [10] (**Inferred** reconciliation).

Top recommendations

1. Find every NetScaler with a SAML IdP profile; those are the exposed systems [1] (**Confirmed** as vendor guidance).
2. Run 14.1-60.58 or 14.1-66.59 and later, 13.1-62.23 and later, or 13.1-37.262 and later for FIPS and NDcPP, and then move to the current fixed build named in the latest NetScaler bulletins: the CTX696604 builds (14.1-72.61, 13.1-63.18, 14.1-72.61 FIPS, 13.1-37.272 FIPS and NDcPP) are the minimum that close the follow-on overread CVE-2026-8451, and KEV has since listed further exploited NetScaler flaws (CVE-2026-19490, CVE-2026-88771, CVE-2026-88772, CVE-2026-88779) [1] [4] [13] (**Confirmed** builds and KEV dates; that the later builds also carry the March fix is **Inferred** from version order).

3. After updating, terminate all active and persistent sessions, as CERT-EU advises; a session ID read out of memory before the patch can still be reused after it unless the session is ended [8] [11] [17] (**Confirmed** as CERT-EU guidance and its stated reason).
4. Snapshot an internet-facing affected appliance before patching, so the evidence survives [8] (**Confirmed** as CERT-EU guidance).
5. Restrict network access to Gateway and AAA virtual servers, and patch internet-facing SAML IdP appliances first [8] (**Confirmed** as CERT-EU guidance).

Scope and method

This brief covers CVE-2026-3055 from reservation (23 February 2026) to KEV catalog 2026.11.10, with companion CVE-2026-4368 and follow-on CVE-2026-8451 as context. The later 2026 NetScaler zero-days (CVE-2026-88771, CVE-2026-88772 and CVE-2026-88779) are a separate event, the subject of their own study, and appear here only in the KEV lineage. Tradecraft stays at advisory level: no request formats, parameters, payloads or exploit steps. Times are UTC.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: Citrix, CVE, NVD, KEV, CISA or CERT-EU
Reported	One security vendor's research or statement, not confirmed by a primary
Demonstrated	Shown in reproducible public research (watchTowr's lab work), or by this study's check of the library's MITRE data
Inferred	This study's reasoning from cited facts

Non-US government advisories other than CERT-EU, and exposure dashboards, were not checked.

Part 1: what happened

Date (2026)	Event	Sources	Grade
23 Feb	The NetScaler CNA reserves CVE-2026-3055	[2]	Confirmed
23 Mar	Citrix publishes CTX696300 for CVE-2026-3055 and CVE-2026-4368; a same-day revision updates the 14.1 affected version and adds 14.1-60.58 as a fixed build	[1]	Confirmed
23 Mar	CNA datePublic 19:20; CVE record published 20:21; NVD publishes at 21:17	[2] [3]	Confirmed
23 Mar	CERT-EU Advisory 2026-003 sees no public evidence of exploitation; Rapid7 reports none and no public proof of concept	[8] [15]	Confirmed (Rapid7 Reported)
27 Mar	watchTowr's honeypots see exploitation; a NetScaler blog post moves CVE disclosures to the Citrix Community site, says the 23 March builds fix both CVEs and says nothing on exploitation	[9] [11]	Confirmed (watchTowr Reported)
30 Mar	CISA adds CVE-2026-3055 to KEV "based on evidence of active exploitation", due 2 April	[4] [6]	Confirmed
31 Mar	CISA's ADP container in the CVE record is last updated; it records Exploitation active, Automatable yes, Technical Impact total; Rapid7 updates its post	[2] [15]	Confirmed (Rapid7 Reported)
17 Jun	NVD's last modification; status Analyzed, CWE-125	[3]	Confirmed
30 Jun	Citrix CTX696604 fixes CVE-2026-8451; NVD publishes it; watchTowr publishes its research	[12] [13] [14]	Confirmed (watchTowr Reported)

The Intelligence Hub's data index carries three dated rows: the KEV row (30 Mar), watchTowr Part 2 (29 Mar) and the CVE-2026-8451 post (30 Jun), which cross-references CVE-2025-5777 [18] (**Confirmed**).

Discrepancies in the record

- **The 14.1 affected range.** The revised bulletin and NVD's CPE data list 14.1 before 14.1-60.58, but the CNA's affected data lists 14.1 below 66.59, and CERT-EU and Rapid7 give the same 14.1 range [1] [2] [3] [8] [15] (**Confirmed**). watchTowr tested 14.1-66.54 as unpatched and 14.1-66.59 as patched [10] (**Demonstrated**). This study reads 14.1-66.x builds before 66.59 as affected (**Inferred**).
- **When exploitation began.** The SSVC entry in the CVE record carries a 23 March timestamp and now reads Exploitation active; the CISA ADP container was last updated on 31 March, and its KEV entry and timeline are dated 30 March [2] (**Confirmed**). The record does not show when the Exploitation value changed, so the 23 March timestamp is not evidence of exploitation that day (**Inferred**).
- **Internal discovery versus outside findings.** The vendor says it identified CVE-2026-3055 internally [1] (**Confirmed**), yet within six days of the bulletin outside researchers showed a second leak site that, by their analysis, the same fix closed [11] (**Demonstrated** for the leak; its attribution to CVE-2026-3055 **Reported**).

Part 2: the technical record

CVE-2026-3055 lets an unauthenticated request read past the memory it should in the SAML IdP login flow and get stale data back [1] [10] (**Confirmed** for the class; the mechanism **Demonstrated**).

What the research showed. watchTowr's Part 1 (28 March) reproduced a small, inconsistently triggered overread on the SAML login path that returns stale memory in a cookie [10] (**Demonstrated**). Part 2 (29 March) found a second overread on the WS-Federation passive endpoint leaking kilobytes per request, including in testing an authenticated administrative session ID, and reported exploitation under way [11] (**Demonstrated**; exploitation **Reported**). watchTowr likens it to CitrixBleed 2 (CVE-2025-5777) [11], Rapid7 to CitrixBleed (CVE-2023-4966) [15] (**Reported**).

Traces. watchTowr reports unusual ns.log entries only with DEBUG logging, and asked Citrix for detection guidance [10] (**Reported**); the bulletin has none [1] (**Confirmed** as an absence on 11 November 2026).

Tooling. Rapid7 offers an authenticated InsightVM and Nexpose check [15] (**Reported**). A Metasploit auxiliary scanner module was proposed on 30 March and merged on 20 May [16] (**Confirmed**), so the Metasploit module that Rapid7's 31 March update called available was an open pull request at that point (**Inferred** from [15] [16]).

CVE	Class	Precondition	CVSS v4.0	Exploitation record
CVE-2026-3055	Memory overread; CWE-125	SAML IdP	9.3	KEV 30 Mar 2026; SSVC active [2] [4]
CVE-2026-4368	Race condition causing user session mixup; CWE-362	Gateway or AAA virtual server, build 14.1-66.54 only	7.7	SSVC none (24 Mar); not in KEV [7] [4]
CVE-2026-8451	Memory overread; CWE-125	SAML IdP	8.8	Not in KEV as of catalog 2026.11.10 [13] [14] [4]

Sources: [1] [2] [4] [7] [13] [14] (**Confirmed**).

The follow-on. watchTowr reported a further SAML IdP overread to Citrix on 28 March, its timeline showing a fix in development on 7 May, expected 29 June as of 14 June and slightly delayed on 25 June; its post calls CVE-2026-3055 "CitrixBleed4(?)" [12] (**Reported**). Citrix fixed the finding as CVE-2026-8451 in CTX696604 on 30 June, alongside CVE-2026-8452, CVE-2026-8655, CVE-2026-10816, CVE-2026-10817 and CVE-2026-13474, for 14.1 before 14.1-72.61, 13.1 before 13.1-63.18, FIPS before 14.1-72.61 FIPS and FIPS and NDcPP before 13.1-37.272 [13] (**Confirmed**).

Part 3: who and why

No primary opened for this study attributes the exploitation to a named group, cluster or country [1] to [8] (**Inferred** from the absence). watchTowr links the source addresses to known threat actors but names none; this study reviewed no indicators [11] (**Reported**).

The CitrixBleed comparison carries weight: KEV records known ransomware use for the two CitrixBleed flaws, CVE-2023-4966 (CitrixBleed, added 18 October 2023) and CVE-2025-5777 (CitrixBleed 2, CWE-125, added 10 July 2025) [4] (**Confirmed**). Joint advisory AA23-325A says LockBit 3.0 affiliates exploited CitrixBleed, drawing on details Boeing shared about an intrusion at Boeing Distribution Inc. [17] (**Confirmed**). None of that

lineage is evidence about who exploited CVE-2026-3055 (**Inferred**).

Part 4: impact and response

Victims. None named in the sources [1] to [15] (see Key facts); the wider record was not checked (**Inferred**).

Response. Cloud Software Group updated Citrix-managed services itself [1] (**Confirmed**). On 11 November 2026 the bulletin still had no exploitation statement or session-termination step [1] (**Confirmed**). CISA's 30 March alert tied the listing to BOD 22-01 for Federal Civilian Executive Branch agencies [6] (**Confirmed**). CERT-EU's 23 March advisory, its only version, carries the steps in Top recommendations 3 to 5 [8] (**Confirmed**).

KEV lineage since 2023, Citrix NetScaler ADC and Gateway (catalog 2026.11.10)	Added
CVE-2023-3519, ransomware use Known	19 Jul 2023
CVE-2023-4966 (CitrixBleed), ransomware use Known	18 Oct 2023
CVE-2023-6548 and CVE-2023-6549	17 Jan 2024
CVE-2025-6543	30 Jun 2025
CVE-2025-5777 (CitrixBleed 2, CWE-125), ransomware use Known	10 Jul 2025
CVE-2025-7775	26 Aug 2025
CVE-2026-3055 (this study), ransomware use Unknown	**30 Mar 2026**
CVE-2026-8452	26 Aug 2026
CVE-2026-19490	9 Sep 2026
CVE-2026-88771 and CVE-2026-88772	27 Sep 2026
CVE-2026-88779	4 Oct 2026

Source: [4] (**Confirmed**).

Part 5: the defender and vulnerability-management view

The precondition is the first filter: an inventory that records which appliances act as a SAML IdP turns a fleet-wide alarm into a defined list [1] (**Inferred** from the vendor's check). The second is the build: with two fixed 14.1 branches, a check that only asks "below 14.1-60.58?" passes a vulnerable 14.1-66.54 [1] [3] [10] (**Inferred**). The target is the current build, not the March one, since KEV has listed four later exploited NetScaler flaws [4] (**Confirmed** listings).

The harder lesson is that a memory-disclosure patch does not recall what already leaked. watchTowr showed a session ID leaking [11] (**Demonstrated**); CitrixBleed sessions were used after the fact [17] (**Confirmed**). That is why CERT-EU's snapshot, update and session-kill sequence matters more than the vendor's update-only guidance [1] [8] (**Inferred**).

What is overstated and what is understated

- **Overstated:** treating every NetScaler as exposed, when the precondition is a non-default SAML IdP profile [1] [15] (**Inferred**). Rapid7 also judges the SAML IdP configuration likely common among organisations that use single sign-on, so the list may not be short [15] (**Reported**). The "CitrixBleed" label is a researcher's analogy (watchTowr, Rapid7), not a vendor or government statement [11] [15] (**Reported**), and no primary opened for this study ties this flaw to ransomware; KEV lists ransomware use as Unknown [4] (**Confirmed** for KEV; the absence **Inferred**).
- **Understated:** the vendor bulletin still has no exploitation note or session-kill step, while CERT-EU and the CitrixBleed lineage say stolen sessions survive patching [1] [8] [17] (**Inferred** from **Confirmed** facts). One CVE covered at least two leak sites and a third followed under a new number, so a single "patched" flag hid an evolving surface [11] [13] (**Demonstrated** and **Confirmed**).

MITRE mappings

Names and tactics come from the library's ATT&CK v20.0, CWE, CAPEC and D3FEND data, and every linked page exists in the `mitre/` tree [19] (**Demonstrated**). No source names ATT&CK ids, so every id is this study's mapping (**Inferred**). No industrial system is involved, so ATT&CK for ICS does not apply.

Groups, software and campaigns

No source attributes the exploitation and ATT&CK has no campaign object for it, so no group or campaign is bound; one software object is related through the CitrixBleed lineage only [1] [4] [11] [19] (**Inferred**; the campaign check **Demonstrated**).

Object	ATT&CK id	Relationship to this record
LockBit 3.0	S1202	Its affiliates exploited CVE-2023-4966, per AA23-325A [17]. Lineage only

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1190	Exploit Public-Facing Application	Initial Access	Honeypot exploitation (27 Mar); KEV listing on evidence of active exploitation (30 Mar)	[4] [6] [11]
T1212	Exploitation for Credential Access	Credential Access	Overread returns an admin session ID (29 Mar)	[11]
T1539	Steal Web Session Cookie	Credential Access	Session ID in leaked memory (watchTowr Part 2, 29 Mar)	[11]
T1550.004	Web Session Cookie	Lateral Movement	Capability, not observed: CERT-EU's session-termination step (23 Mar); CitrixBleed lineage (AA23-325A)	[8] [17]

Fit notes (**Inferred**): T1212 and T1539 both describe the leak; the sources show the token, not its use. T1550.004 is a capability rather than an observed act, and the layer scores it lowest.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-125	Out-of-bounds Read	CVE-2026-3055 (Citrix, NVD, KEV); CVE-2026-8451 (Citrix); CVE-2025-5777 (KEV)	[1] [3] [4] [13]
CWE-362	Concurrent Execution using Shared Resource with Improper Synchronization	CVE-2026-4368	[1] [7]

CAPEC	Name	Via	Where it meets the record
CAPEC-540	Overread Buffers	CWE-125	The SAML and WS-Federation overreads [10] [11]
CAPEC-60	Reusing Session IDs (aka Session Replay)	T1550.004	Leaked admin session ID; session-kill advice [8] [11] (**Inferred** fit)

The library relates CWE-362 to CAPEC-26 and CAPEC-29, not bound because CVE-2026-4368 has no exploitation record [7] [19] (**Demonstrated**). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Library-mapped techniques	Where it meets the record
Inbound Traffic Filtering	T1190	CERT-EU's access restriction for Gateway and AAA servers [8]
Software Update	T1212	The fixed builds in CTX696300 and CTX696604 [1] [13]
Asset Vulnerability Enumeration	T1212	The SAML IdP profile check; Rapid7's authenticated check [1] [15]
Authentication Cache Invalidation	T1539, T1550.004	Terminating sessions after updating [8]
Credential Revocation	T1539, T1550.004	The same step, for leaked session IDs [8] [11]

CERT-EU's step also corresponds to Session Termination, which the library does not relate to these techniques [8] [19] (**Inferred**). See the D3FEND Reference.

Navigator layer

The study's ATT&CK Navigator layer is `navigator/library-layers/citrix-netscaler-cve-2026-3055.json` (open in Navigator), listed on the Navigator layers page, pinned to ATT&CK v20 Enterprise. Scores: 75, a KEV entry or government record; 50, public research; 25, a capability rather than an observed act.

Cross-cutting themes

- **Memory disclosure on the edge is a recurring class.** CitrixBleed, CitrixBleed 2, CVE-2026-3055 and CVE-2026-8451 all disclose memory from NetScaler Gateway, AAA or SAML IdP authentication services [4] [12] [13] (**Confirmed** per CVE; the grouping as one class is **Inferred**). See the Edge Device Security Reference; for an earlier NetScaler wave, Chronicle 2019 and Chronicle 2020; for CitrixBleed, Chronicle 2023; for CitrixBleed 2, Chronicle 2025; and for the September and October 2026 zero-days, their study [20].
- **The identity provider is a high-value target.** A SAML IdP flaw sits in front of every application the appliance signs users into [1] (**Inferred**). Change Healthcare 2024 shows what a Citrix remote-access portal can open up once an attacker holds a working login, there through stolen credentials and no MFA rather than a flaw [20] (**Inferred** comparison).
- **"Found internally" and "found by others" can both be true.** Outside research widened the known surface within days [11] (**Demonstrated**), and watchTowr reports that its further finding became CVE-2026-8451 three months later [12] [13] (**Reported**; the fix **Confirmed**). Both statements can be true at once (**Inferred**).

Sources

All sources were opened on 11 November 2026; the library pages in [20] were opened again on 13 November 2026, when the study was added to the library.

#	Source	URL	Opened	Grade
1	Citrix, CTX696300, NetScaler ADC and NetScaler Gateway Security Bulletin for CVE-2026-3055 and CVE-2026-4368, 23 Mar 2026 (revised the same day)	support.citrix.com/external/article/CTX696300	2026-11-11	Confirmed
2	CVE Program record CVE-2026-3055 (CNA NetScaler, CISA ADP Vulnrichment)	cveawg.mitre.org/api/cve/CVE-2026-3055	2026-11-11	Confirmed
3	NVD, CVE-2026-3055 (page and API 2.0 record)	nvd.nist.gov/vuln/detail/CVE-2026-3055	2026-11-11	Confirmed
4	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
5	CISA, KEV catalog entry for CVE-2026-3055	cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-3055	2026-11-11	Confirmed
6	CISA, CISA Adds One Known Exploited Vulnerability to Catalog, 30 Mar 2026	cisa.gov/news-events/alerts/2026/03/30/cisa-adds-one-...	2026-11-11	Confirmed
7	CVE Program record CVE-2026-4368 (CNA NetScaler, CISA ADP Vulnrichment)	cveawg.mitre.org/api/cve/CVE-2026-4368	2026-11-11	Confirmed
8	CERT-EU, Security Advisory 2026-003, 23 Mar 2026	cert.europa.eu/publications/security-advisories/2026-003/	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
9	NetScaler, Important update: CVE disclosures now live on the Citrix Community site, 27 Mar 2026	netscaler.com/blogs/2026-03/important-update-...	2026-11-11	Confirmed
10	watchTowr Labs, The Sequels Are Never As Good, But We're Still In Pain (CVE-2026-3055 memory overread), 28 Mar 2026	labs.watchtowr.com/the-sequels-are-never-as-good-...	2026-11-11	Demonstrated
11	watchTowr Labs, Please, We Beg, Just One Weekend Free Of Appliances (CVE-2026-3055 Part 2), 29 Mar 2026	labs.watchtowr.com/please-we-beg-just-one-weekend-...	2026-11-11	Demonstrated (exploitation claim Reported)
12	watchTowr Labs, CitrixBleed To Infinity And Beyond (CVE-2026-8451), 30 Jun 2026	labs.watchtowr.com/citrixbleed-to-infinity-and-beyond-...	2026-11-11	Reported
13	Citrix, CTX696604, security bulletin for CVE-2026-8451 and five other CVEs, 30 Jun 2026	support.citrix.com/external/article/CTX696604	2026-11-11	Confirmed
14	NVD, CVE-2026-8451 (API 2.0 record)	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-8451	2026-11-11	Confirmed
15	Rapid7, ETR: CVE-2026-3055 Citrix NetScaler ADC and NetScaler Gateway out-of-bounds read, 23 Mar 2026, updated 31 Mar 2026	rapid7.com/blog/post/etr-cve-2026-3055-...	2026-11-11	Reported
16	Rapid7, metasploit-framework pull request #21204, opened 30 Mar 2026, merged 20 May 2026	github.com/rapid7/metasploit-framework/pull/21204	2026-11-11	Confirmed
17	CISA and partners, AA23-325A, on LockBit 3.0 affiliates exploiting CitrixBleed, 21 Nov 2023	cisa.gov/news-events/cybersecurity-advisories/aa23-325a	2026-11-11	Confirmed
18	TeamStarWolf Intelligence Hub, feed and data index	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Confirmed
19	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `software.jsonl`, `campaigns.jsonl` and `technique_to_d3fend.jsonl` (ATT&CK v20.0), `data/weaknesses/cwe.jsonl` and `capec.jsonl`, and the `mitre/` page tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Demonstrated
20	TeamStarWolf references and case studies on Citrix: Edge Device Security, Chronicle 2019, 2020, 2023 and 2025, Change Healthcare, the Citrix NetScaler zero-days of September and October 2026	/EDGE_DEVICE_SECURITY_REFERENCE.md, /case-studies/CHRONICLE_2019.md, /case-studies/CHRONICLE_2020.md, /case-studies/CHRONICLE_2023.md, /case-studies/CHRONICLE_2025.md, /case-studies/CHANGE_HEALTHCARE_2024.md, /case-studies/CITRIX_NETSCALER_SEPTEMBER_2026.md	2026-11-13	Confirmed

Not opened, so not cited as sources: the Citrix Community security-updates page (access refused), advisories from NCSC UK, the Canadian Cyber Centre, ASD ACSC, NCSC-NL and BSI, any CISA joint advisory naming actors for this CVE, and exposure dashboards.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Chronicle 2019, Chronicle 2020, Chronicle 2023, Chronicle 2025, The Year 2026 in Intrusions, Change Healthcare 2024, The Ransomware Ecosystem, Log4Shell, Timeline
- Other 2026 studies of exploited edge appliances: The Citrix NetScaler zero-days of September and October 2026, The Ivanti Connect Secure zero-day chain, The FortiCloud SSO authentication bypass, The PAN-OS GlobalProtect authentication bypass, The Check Point Remote Access VPN IKEv1 authentication bypass, The Cisco Catalyst SD-WAN authentication bypass
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Edge Device Security Reference, Citrix NetScaler platform page, NetScaler ADC and Gateway
- Vulnerability Management Reference, Vulnerability Prioritization Reference
- Techniques: T1190 Exploit Public-Facing Application, T1212 Exploitation for Credential Access, T1539 Steal Web Session Cookie, T1550.004 Web Session Cookie
- CAPEC: CAPEC-540 Overread Buffers, CAPEC-60 Reusing Session IDs (aka Session Replay)
- Software (lineage only): S1202 LockBit 3.0
- Navigator layers, including this study's layer, citrix-netscaler-cve-2026-3055.json
- The Team Star Wolf Intelligence Hub
- All case studies